

Email Analysis — Investigation Report

Findings

Delivered-To	themajoronearth@gmail.com
Date/Time (originating)	Tue, 26 Jan 2021 01:41:18 -0500 (EST)
Date/Time (Google receipt)	Mon, 25 Jan 2021 22:41:18 -0800 (PST) — same instant, different timezone
Subject	“A Hope to CoCanDa”
From (claimed)	“Bill” <billjobs@microapple.com>
Return-Path	billjobs@microapple.com
Reply-To	negeja3921@pashter.com (mismatched domain vs. From address)
Sending Host / Sender IP	emkei.cz [93.99.104.210]
SPF Result	FAIL — google.com: domain of billjobs@microapple.com does not designate 93.99.104.210 as a permitted sender
Attachment (as declared)	PuzzleToCoCanDa.pdf, Content-Type: application/pdf, Base64-encoded
Attachment (true type)	ZIP archive — file signature 50 4B 03 04 (“PK..”), not a genuine PDF
Archive Contents	PuzzleToCoCanDa/DaughtersCrown, PuzzleToCoCanDa/GoodJobMajor, PuzzleToCoCanDa/Money.xlsx
DaughtersCrown (true type)	JPEG image — file signature FF D8 FF E0
GoodJobMajor (true type)	PDF document — file signature 25 50 44 46
Money.xlsx (true type)	Genuine Microsoft Excel (Open XML) spreadsheet — signature 50 4B 03 04 plus Open XML markers
Hidden Payload	Money.xlsx, Sheet3 — Base64 string concealed via white-on-white text formatting; decodes to a message beginning “the Martian Colony...”
Tools Used	CyberChef (Base64 decode/encode, To Hex), HxD (hex/file-signature inspection), Gary Kessler File Signatures reference

Investigation Summary

On 26 Jan 2021, themajoronearth@gmail.com received a spoofed email from “Bill” <billjobs@microapple.com>, actually sent via the emkei.cz spoofing service (IP 93.99.104.210). SPF failed and the Reply-To domain (pashter.com) did not match the sender domain. The decoded body was an extortion-style message demanding “1 Billion CoCanDs” and pointing to a puzzle attachment, with the hint “Don’t Trust Your Eyes.”

The attachment, PuzzleToCoCanDa.pdf, was declared as a PDF but its file signature (50 4B 03 04) showed it was actually a ZIP archive. Inside, two extensionless files — DaughtersCrown and GoodJobMajor — were identified via magic bytes as a JPEG and a PDF respectively. A third file, Money.xlsx, was a genuine spreadsheet containing a hidden worksheet with white-on-white Base64 text that decoded to a further message (“the Martian Colony, beside interpanetary spaceport”).

Who, What, When, Where, Why, How

Who — Recipient: themajoronearth@gmail.com. Claimed sender: “Bill” <billjobs@microapple.com> — identity is spoofed. Actual sending infrastructure: the emkei.cz spoofing service from IP 93.99.104.210. Reply-To address: negeja3921@pashter.com, on a domain unrelated to the claimed sender.

What — An extortion-themed phishing/puzzle email demanding “1 Billion CoCanDs” was delivered with a Base64-encoded ZIP attachment disguised as PuzzleToCoCanDa.pdf. The archive contained further disguised files

(an image and a PDF with no extensions — DaughtersCrown and GoodJobMajor) plus a genuine spreadsheet, Money.xlsx, containing a hidden Base64-encoded message concealed with white-on-white text formatting.

When — Tue, 26 Jan 2021, 01:41:18 EST (originating server) / Mon, 25 Jan 2021, 22:41:18 PST (Google receiving server) — same moment in time. This is a single email with no indication of recurring or ongoing delivery.

Where — The recipient mailbox is themajoronearth@gmail.com (Gmail). Analysis of the message and its attachments was carried out on an analyst workstation using CyberChef, Garykessler, HxD and ExifTool.

Why — The fictional “CoCanD” currency, alien-abduction narrative, riddle-style hint (“Don’t Trust Your Eyes”), and layered hidden-file puzzle indicate this was built as a CTF exercise in email header analysis, encoding, and file-signature verification.

In a real-world environment, these techniques could also be used to bypass security controls, conceal malicious content or persuade a recipient to interact with an unsafe attachment.

How — The sender used the emkei.cz email-spoofing service to forge the From address as billjobs@microapple.com, which failed SPF and used a mismatched Reply-To domain (pashter.com). The email body and its attachment were Base64-encoded. Once decoded, the attachment’s true file type (ZIP, not PDF) was identified via its file signature (50 4B 03 04) rather than its file name or declared content type. Files extracted from the archive (DaughtersCrown, GoodJobMajor) were similarly disguised with missing extensions and were only correctly identified through file-signature analysis in a hex editor, revealing a JPEG and a PDF respectively. A further message was concealed inside the extracted Money.xlsx spreadsheet using white-text-on-white-background formatting and Base64 encoding, only surfaced by clearing cell formatting on an apparently blank worksheet.

Recommendations

- Do not trust file names, declared content types, or extensions when handling email attachments; always verify true file type via file-signature (magic byte) analysis before opening or forwarding, as demonstrated with PuzzleToCoCanDa.pdf and the files inside it.
- Configure the mail gateway/filter to flag or quarantine inbound mail where SPF fails for the claimed sending domain, as occurred here for microapple.com.
- Add a detection rule for mismatched From and Reply-To domains (microapple.com vs. pashter.com), a common phishing/BEC indicator.
- Blocklist known free email-spoofing/relay services such as emkei.cz at the mail gateway where they are not needed for legitimate business use.
- Add detection logic for archives disguised with document extensions or content types (e.g., a ZIP presented as a .pdf) and for Base64-encoded content in email bodies or attachments, routing matches to sandboxing for automated analysis.
- Search mail logs for the identified indicators (sender IP 93.99.104.210, domains microapple.com and pashter.com, and the emkei.cz service) to determine whether other mailboxes received the same or similar messages.
- Since this message is assessed as a training/CTF exercise rather than a live attack, no incident-response escalation is required here; if the same technique pattern (spoofed sender, SPF fail, Base64 body, disguised ZIP attachment) is seen in a non-exercise context, treat it as a credible phishing attempt and isolate any host where the attachment was opened or extracted.